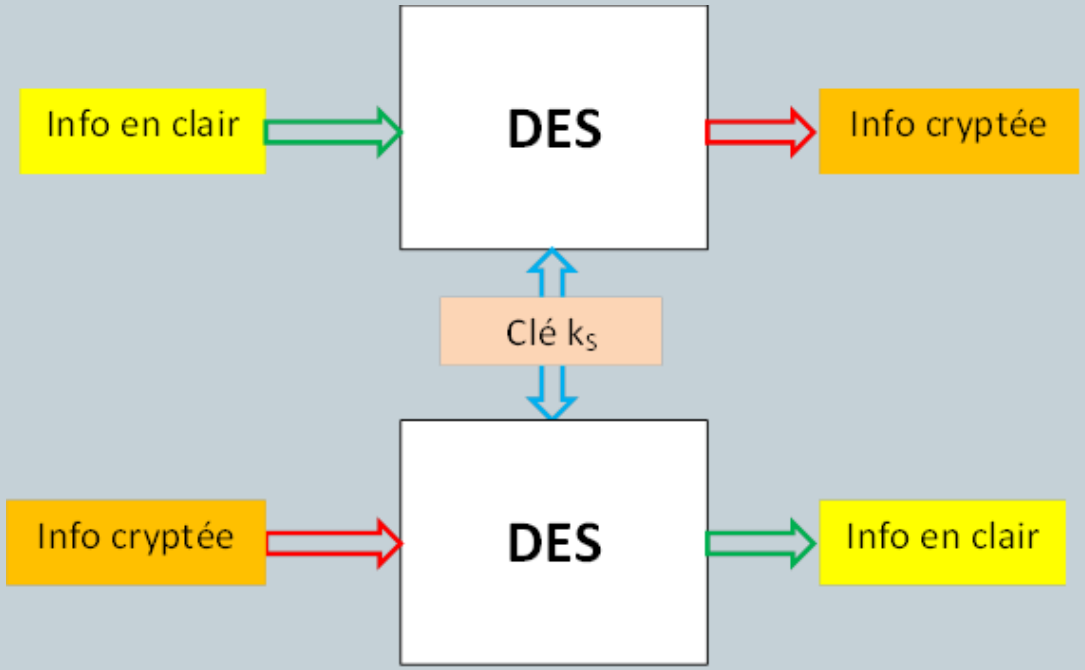
INFRASTRUCTURE
de
CLES PUBLIQUES

Les outils cryptographiques

- La cryptographie symétrique
  - Exemples : DES, 3DES, AES, …
- La cryptographie asymétrique
  - Exemples : RSA, DSS, …
- Les fonctions de hachage
  - Exemples : MD5, SHA1, …

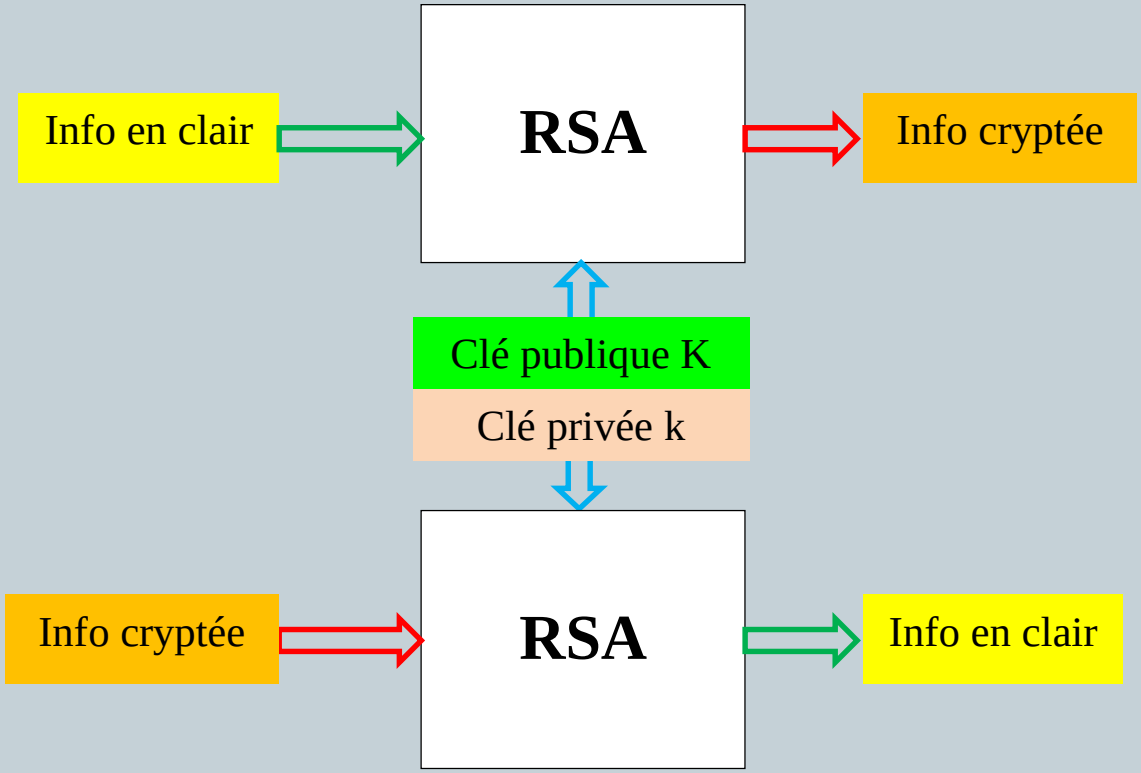
La cryptographie symétrique

- Principe
  - une seule clé pour crypter et décrypter



La cryptographie asymétrique

- Principe
  - une clé pour crypter et une autre pour décrypter



Les fonctions de hachage

- Principe
  - Un algorithme pour hacher une information

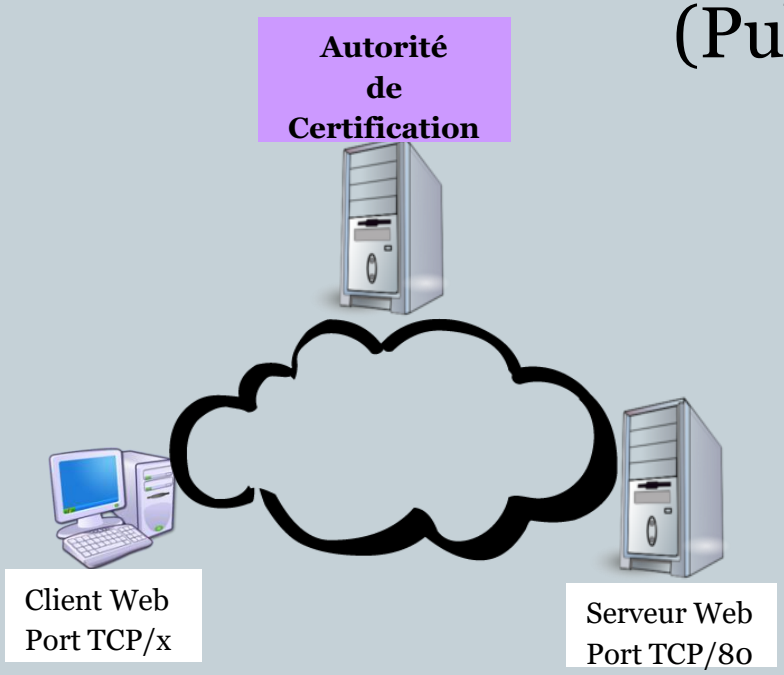
  - Chaque information a une signature (quasi) unique

```
$ echo bonjour | md5sum
94baaad4d1347ec6e15ae35c88ee8bc8

$ echo Bonjour | md5sum
894dddf3304cbcb0fe04f7c2bbd56073
```

Vue d'ensemble

- infrastructure de clés publiques = PKI
  (Public Key Infrastructure)



- Autorité de certification ► service de certificats

L’autorité de certification

- Toute infrastructure de clés publiques est basée sur un serveur de certificats désigné comme l’autorité de certification

- L’autorité de certification est responsable de la gestion de l’ensemble des certificats des entités d’un même domaine :
  - Création et attribution
  - Modification
  - Révocation

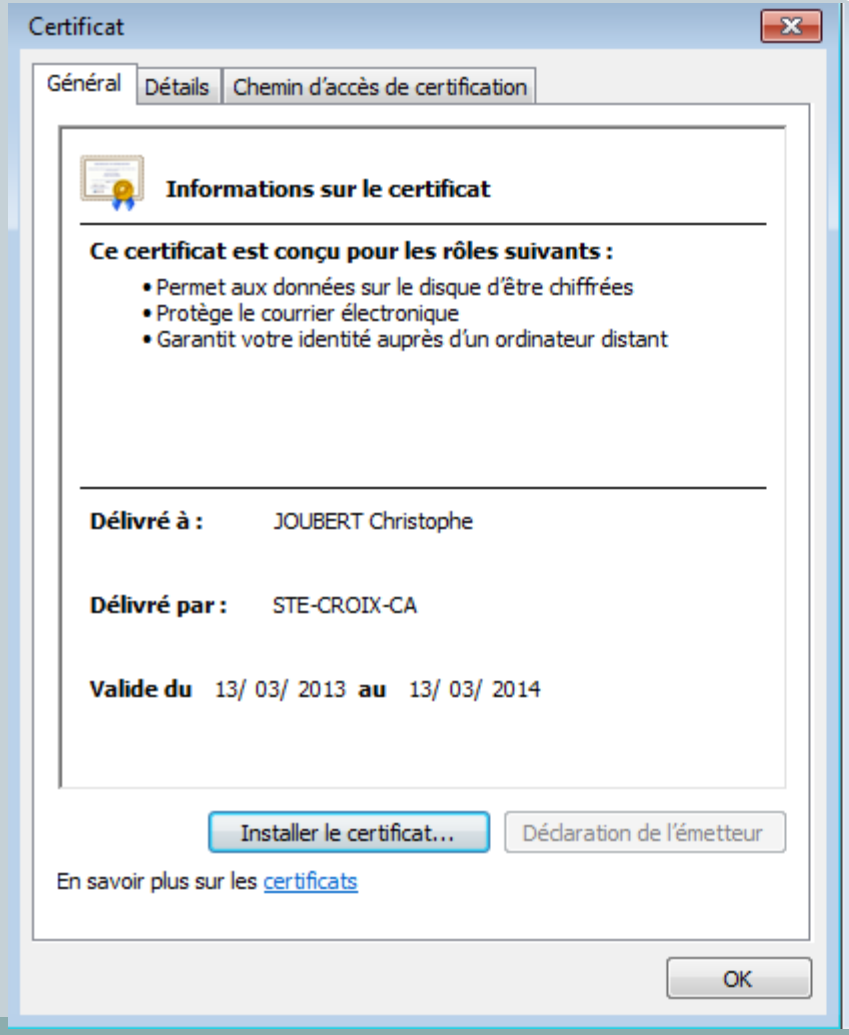
Qu’est ce qu’un certificat ?

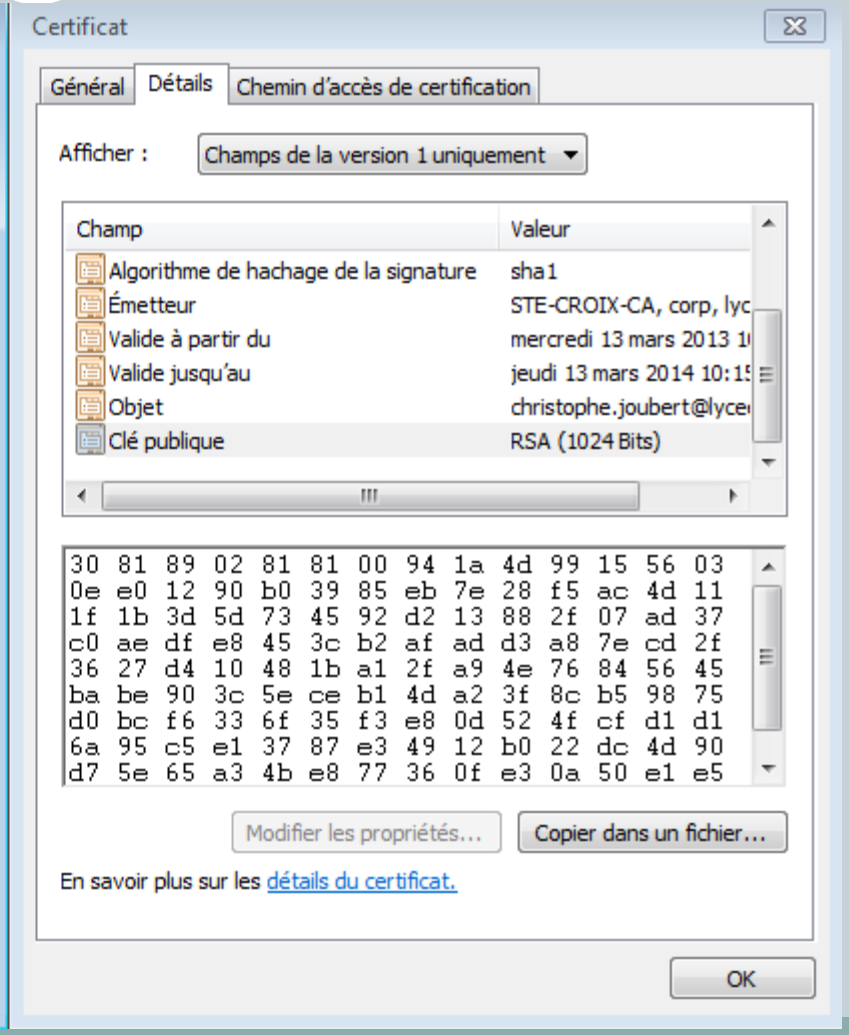
- Un certificat permet à une entité d’authentifier une autre entité.
- Une entité peut être :
  - Une personne
  - Un service
  - Une autorité de certification !
  - …
- Un certificat est délivré par une autorité de certification avec laquelle l’entité «authentificatrice» a établi une relation de confiance
- Un certificat a un rôle analogue à une carte d’identité délivrée par une préfecture

A quoi ressemble un certificat ?

- Un certificat détenu par une entité est un fichier contenant différentes informations comme :
  - L'identité de l'entité
  - La période de validité du certificat
  - La clé publique de l'entité
  - La signature du certificat par la clé privée de l'autorité de certification
  - …

Exemple de certificat





Comment utiliser un certificat ?

- Scénario
  - Un client web demande à un service web de s'authentifier
  - Le service web envoie au client son certificat
  - Le client web vérifie l'identité présente dans le certificat
  - Le client web vérifie la période de validité du certificat
  - Le client web vérifie si la signature du certificat a été produite par une autorité de certification connue.

  ► Si toutes les vérifications sont validées, le client web peut utiliser la clé publique du service web pour assurer la confidentialité des échanges à venir, ce qui est indispensable s'il s'agit d'un service web de commerce en ligne.

Comment vérifier la signature d'un certificat ?

- Signature *(par l'autorité de certification)*
  - Un certificat est composé d'un ensemble d'informations I suivi d'une signature S
  - La signature S est obtenue en calculant une empreinte E (grâce à une fonction de hachage comme SHA1) qui est ensuite cryptée grâce à un cryptosystème asymétrique comme RSA)
    - E = SHA1(I)
    - S = RSA(E, k) où k est la clé privée de l'autorité de certification

- Vérification *(par le client web)*
  - L'empreinte E est calculée, décryptée …
    - E = SHA1(I)
    - E' = RSA(S, K) où K est la clé publique de l'autorité de certification
  - … et comparée
    - E = E' ? S' il y a égalité, le client web peut en déduire que seule l'autorité de certification a pu émettre cette signature ainsi que le contenu du certificat et que par conséquent le service web est digne de confiance